

Clase 315 — MFA y gestión de accesos privilegiados (PAM)

Parte: **17 — Profundización para certificaciones** · Fuente: *NIST SP 800-63B — Digital Identity Guidelines* · (ISC)² *CISSP Official Study Guide — Dominio 5*  Duración estimada: **100 min** · Nivel: **Avanzado**

Objetivo

Reforzar la autenticación con **múltiples factores (MFA)** —incluyendo passkeys/FIDO2 resistentes al phishing— y gobernar las cuentas más peligrosas de la organización mediante **PAM** (Privileged Access Management): bóvedas de credenciales, acceso *just-in-time* (JIT), grabación de sesión y mínimo privilegio para administradores. Cierra el bloque de identidad de esta parte con los controles que más reducen el riesgo de compromiso de cuentas, alineado con NIST SP 800-63B y CISSP.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Clasificar** los factores de autenticación y evaluar su fuerza y resistencia al phishing.
2. **Explicar** cómo funcionan TOTP, push, FIDO2/WebAuthn y passkeys, y sus diferencias.
3. **Justificar** por qué SMS-OTP es un factor débil según NIST SP 800-63B.
4. **Diseñar** una política MFA por nivel de riesgo con autenticación adaptativa.
5. **Explicar** las capacidades de una solución PAM: bóveda, rotación, JIT y grabación.
6. **Diseñar** un flujo de acceso privilegiado con aprobación y trazabilidad completa.

Temas

#	Tema	Por qué importa
1	Factores de autenticación	Base de MFA y de los niveles AAL
2	MFA y su fuerza relativa	No todos los segundos factores protegen igual
3	FIDO2 / WebAuthn / passkeys	Resistencia al phishing por diseño
4	Autenticación adaptativa / basada en riesgo	Equilibra seguridad y fricción
5	Cuentas privilegiadas	Son el objetivo prioritario del atacante
6	PAM: bóveda, rotación, checkout	Elimina credenciales compartidas y estáticas
7	JIT y zero standing privilege	Reduce la ventana de exposición del privilegio
8	Grabación y auditoría de sesión	Trazabilidad y disuasión del abuso

Definiciones y características

- **Factor de autenticación:** categoría de prueba de identidad — **algo que sabes** (contraseña/PIN), **algo que tienes** (token, teléfono, llave) y **algo que eres** (biometría). MFA exige combinar factores de **categorías distintas**.
- **MFA:** autenticación con dos o más factores independientes. Característica: aunque roben la contraseña, falta el segundo factor.
- **TOTP:** código de un solo uso basado en tiempo (RFC 6238), generado por app autenticadora. Mejor que SMS, pero aún *phishable* (el usuario puede teclearlo en un sitio falso).
- **FIDO2 / WebAuthn:** estándar de autenticación con criptografía de clave pública ligada al origen (dominio). Característica: **resistente al phishing** porque la firma no funciona en un dominio falso. Las **passkeys** son credenciales FIDO sincronizables o ligadas a dispositivo.
- **AAL (Authenticator Assurance Level):** nivel de garantía de autenticación de NIST SP 800-63B, de AAL1 a AAL3; AAL3 exige un autenticador criptográfico de hardware (p. ej. FIDO2).
- **PAM (Privileged Access Management):** disciplina y herramientas para controlar cuentas con privilegios elevados: bóveda de credenciales, rotación, checkout y grabación de sesión.
- **JIT (Just-in-Time access):** conceder privilegio solo cuando se necesita y por tiempo limitado, revocándolo después. Tiende a **zero standing privilege** (sin privilegios permanentes).
- **Cuenta privilegiada:** cuenta con permisos elevados (root, domain admin, cuentas de servicio con alto acceso). Su compromiso suele implicar control total del entorno.

Herramientas y preparación

- Una **app autenticadora TOTP** (Google Authenticator, Aegis, etc.) y, si tienes, una **llave FIDO2** (YubiKey, o passkey del sistema operativo/navegador) para probar WebAuthn en sitios de demostración propios (p. ej. el demo oficial de WebAuthn).
- **Keycloak** u otro IdP de laboratorio para configurar políticas MFA por flujo de autenticación.
- Documento de referencia **NIST SP 800-63B** (AAL, requisitos de autenticadores).
- Para PAM: material conceptual de una solución (CyberArk, Delinea, HashiCorp Vault, Microsoft Entra PIM). Para el ejercicio basta el diseño del flujo; no necesitas desplegar la herramienta.

Laboratorio guiado — Política MFA y flujo de acceso privilegiado

Sobre "**NovaSalud**", integrando lo visto en las clases 313 y 314.

1. **Inventario de factores.** Lista los métodos disponibles (contraseña, SMS-OTP, TOTP, push, FIDO2/passkey, biometría) y clasifícalos por categoría y por resistencia al phishing.
2. **Política MFA por riesgo.** Define reglas: (a) acceso normal a apps internas → contraseña + TOTP/push; (b) acceso a datos **Restringido** o desde red no confiable → exige **FIDO2/passkey**; (c) administradores → siempre AAL3 (FIDO2 de hardware). Justifica cada nivel.
3. **Autenticación adaptativa.** Añade señales de riesgo (ubicación imposible, dispositivo nuevo, hora atípica) que eleven el factor exigido o bloqueen. Documenta qué señal dispara qué acción.
4. **Inventario de cuentas privilegiadas.** Enumera al menos 5 (admin de dominio, root de servidores, admin de la base de datos clínica, admin del IdP, cuenta de servicio de backups).
5. **Diseña el flujo PAM (checkout).** Para "admin de la base de datos clínica" describe: el admin solicita acceso → aprobación (manager/on-call) → PAM entrega credencial desde la **bóveda** por tiempo limitado (JIT) → la sesión se **graba** → al terminar, la contraseña se **rota**.

- 6. **Zero standing privilege.** Rediseña para que ningún admin tenga privilegio permanente: el acceso elevado se concede bajo demanda y expira. Explica cómo reduce la superficie de ataque.
- 7. **Break-glass.** Define una cuenta de emergencia: credenciales en bóveda sellada, uso que dispara alerta inmediata y revisión obligatoria posterior. Evita que quede como puerta trasera.
- 8. **Trazabilidad.** Especifica qué se registra (quién, qué credencial, cuándo, aprobador, sesión grabada) y cómo alimenta la recertificación de la clase 313.

 Ejercicios

- 1. Clasifica 6 métodos de autenticación por categoría de factor y por resistencia al phishing.
- 2. Explica por qué "contraseña + PIN" **no** es verdadera MFA.
- 3. Describe, a alto nivel, cómo WebAuthn impide el phishing que sí afecta a TOTP.
- 4. Diseña una política MFA de 3 niveles de riesgo con el factor exigido en cada uno.
- 5. Dibuja el flujo completo de checkout de una credencial privilegiada con aprobación y rotación.
- 6. Justifica la adopción de zero standing privilege frente a un modelo de admin permanente.

 Reto verificable

Entrega un **Plan de MFA y PAM** para NovaSalud que incluya: la clasificación de factores, la política MFA por nivel de riesgo con adaptativa, el inventario de cuentas privilegiadas, el flujo PAM de checkout (aprobación → JIT → bóveda → grabación → rotación) y la política de break-glass.

Criterio de aceptación: dado el escenario "un administrador necesita acceso urgente a la base de datos clínica a las 3 a. m.", tu plan describe exactamente qué factor MFA se le exige, cómo obtiene la credencial, por cuánto tiempo, qué queda registrado y cuándo se revoca — sin que ninguna credencial privilegiada quede activa de forma permanente.

 Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
MFA por SMS considerado "seguro"	SMS es susceptible a SIM swapping e interceptación (NIST lo desaconseja). Migra a TOTP o FIDO2.
Usuarios aprueban push sin mirar (MFA fatigue)	Bombardeo de notificaciones. Usa number matching o pasa a FIDO2/passkeys.
Admins con privilegio permanente 24/7	Ventana de exposición enorme. Aplica JIT y zero standing privilege.
Contraseña de root compartida en un gestor de equipo	Sin trazabilidad ni rotación. Usa una bóveda PAM con checkout individual.
Cuenta break-glass usada como acceso rutinario	Se convierte en puerta trasera. Sella, alerta en cada uso y revisa después.
MFA sin cubrir el IdP ni el propio PAM	El eslabón de control queda expuesto. Protege IdP y PAM con el factor más fuerte.

? Preguntas frecuentes

? **¿Por qué se dice que FIDO2/passkeys son "resistentes al phishing"?** Porque la credencial criptográfica está ligada al **origen** (dominio) real. Si el usuario llega a un sitio falso, la firma no se genera para ese dominio, así que no hay nada que el atacante pueda reutilizar — a diferencia de un TOTP, que el usuario puede teclear en la web fraudulenta.

? **¿MFA hace innecesarias las buenas contraseñas?** No. MFA es una capa adicional; la contraseña sigue siendo un factor. NIST SP 800-63B recomienda frases largas, verificar contra listas de contraseñas comprometidas y evitar rotaciones forzadas sin motivo.

? **¿Qué diferencia hay entre PIM y PAM?** Se solapan. PAM es el término amplio (bóveda, rotación, sesiones). PIM (Privileged Identity Management) suele referirse a la elevación temporal de roles/identidades privilegiadas (JIT). En la práctica, muchas plataformas ofrecen ambas capacidades.

? **¿Es obligatorio grabar todas las sesiones privilegiadas?** Depende del riesgo y de la normativa, pero para acceso a datos sensibles o sistemas críticos la grabación aporta trazabilidad, disuasión y evidencia forense. Debe equilibrarse con la privacidad y comunicarse al personal.

Referencias

- NIST SP 800-63B — *Digital Identity Guidelines: Authentication and Lifecycle Management*. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- FIDO Alliance / W3C — *WebAuthn* y passkeys. <https://www.w3.org/TR/webauthn-2/>
- (ISC)² — *CISSP Official Study Guide*, 9.^a ed., Dominio 5 IAM (MFA y acceso privilegiado).
- RFC 6238 — *TOTP: Time-Based One-Time Password Algorithm*. <https://www.rfc-editor.org/rfc/rfc6238>
- CISA — *Implementing Phishing-Resistant MFA*. <https://www.cisa.gov/resources-tools/resources/implementing-phishing-resistant-mfa>

Siguiente clase

Clase 316 - Modelos de seguridad y arquitectura (Bell-LaPadula, Biba, Clark-Wilson)